

A certified cyber range: scoring automated defenders with provable residual-risk guarantees on real ATT&CK structure

2026-09-21 (work-in-progress, version 0.1.0)

Abstract

Autonomous cyber-defense systems are judged almost entirely by *empirical* outcomes—attack-success rate, flags captured—which say nothing provable about the residual risk a defender leaves behind. We describe a small *cyber range* that scores automated defenders with a *provable* verdict instead. Built on the real MITRE ATT&CK Enterprise kill chain (v17.1, 44 mitigations) and an evidence-anchored hospital-ransomware impact model, the range returns, for any control portfolio a defender proposes, a distribution-free *guaranteed/possible* adequacy certificate—the worst-case probability that at least k clinical services suffer simultaneous sustained outage stays below ε , over all dependence structures and all parameter values in an interval uncertainty set. We benchmark four reference automated defenders across 24 adaptive threat regimes (assumed vs. real CIPHER-derived degradation, an ε grid, $k = 1..4$). An exact optimiser certifies at a mean cost of 1.6 controls; a certificate-guided greedy defender is close behind (2.6), while a certificate-blind coverage heuristic (4.1) and a random policy (10.4) pay much more, quantifying the value of certificate feedback. The defender API is agent-agnostic, so an agentic/LLM defender drops in unchanged—the intended next step. This is an evaluation-environment contribution, not a new theorem or a validated real defense.

1 The range

A defender chooses a *control portfolio*: a set of ATT&CK mitigations (M####). Via the real *mitigates* edges, each mitigation lowers the success probability of the techniques it covers, and the kill-chain reachability to the ransomware impact objective composes those into a per-clinical-service sustained- outage probability. The range’s **score** is the certificate, not a sampled outcome: worst- and best-corner evaluation over the interval uncertainty set gives a *guaranteed* verdict (adequate even at the adverse corner) and a *possible* one (adequate only at the favourable corner); the catastrophic k -of- n event uses the sharp closed-form aggregation bound (a min over dependence structures), so the verdict holds whatever the true correlation between service failures. The primary adequacy target is this catastrophic verdict, because it varies with every regime axis. The observation (named mitigations, techniques covered, stages touched), the action (add/remove a mitigation), and the certified score form an agent-agnostic API.

2 Reference defenders and regimes

We score four automated (non-LLM) defenders: an *exact* minimum-cost optimiser (budget-bounded search, feasible because adequacy is monotone in the portfolio); a *greedy* defender that adds the mitigation with the largest worst-case reachability reduction (certificate-guided); a *coverage* heuristic that maximises techniques covered while ignoring the certificate; and a seeded *random* policy.

Table 1: Reference defenders by cost-to-certify across all 24 regimes: fraction of regimes certified within the search, mean controls when certified, and the same split by assumed vs. real (CIPHER) degradation.

Defender	Certified (%)	Mean controls	Assumed	CIPHER
Optimal (exact)	79	1.6	1.7	1.6
Greedy (certificate)	100	2.6	2.8	2.3
Coverage (blind)	100	4.1	4.3	3.8
Random	100	10.4	11.5	9.3

Table 2: Cost-to-certify per regime (assumed degradation): exact optimum vs. the three heuristics. “>4” means the exact optimum exceeds the search cap.

ε	k	Optimal	Greedy	Coverage	Random
0.10	1	2	2	3	9
0.10	2	1	1	2	4
0.10	3	1	1	1	1
0.10	4	0	0	0	0
0.05	1	3	4	6	17
0.05	2	2	2	3	9
0.05	3	1	1	2	9
0.05	4	1	1	2	2
0.01	1	>4	7	10	27
0.01	2	>4	6	9	22
0.01	3	>4	5	7	20
0.01	4	4	4	7	18

Each is scored across 24 regimes: assumed vs. real CIPHER-derived degradation, adequacy levels $\varepsilon \in \{0.10, 0.05, 0.01\}$, and catastrophic thresholds $k = 1..4$. The reported metric is *cost-to-certify*: the smallest portfolio a defender reaches that the range certifies as adequate.

3 Results

Undefended, the worst-case “at least one clinical service” outage probability is 44.9%, far above any ε , so defense is required. Table 1 ranks the defenders by cost-to-certify across the sweep: the exact optimum averages 1.6 controls, the certificate-guided greedy defender 2.6, the certificate-blind coverage heuristic 4.1, and random 10.4—so *using the certificate as feedback roughly halves the control burden* relative to a structure-only heuristic. Grounding degradation in the real CIPHER corpus rather than the assumed prior lowers greedy’s mean cost from 2.8 to 2.3 controls. Table 2 shows the optimality gap per regime (assumed degradation): the greedy defender is at or within one control of the exact optimum almost everywhere, whereas the blind heuristic’s gap is larger; at the headline regime ($\varepsilon = 0.05$, $k = 1$) the exact optimum is 3 controls versus greedy 4, coverage 6, and random 17. The exact optimiser is computed within the search cap in 79% of regimes (the strictest ε needs larger portfolios than the cap).

4 Scope and limitations

This is a first-of-kind *evaluation environment*, realistically a work-in-progress contribution—not a new theorem (the certificate and the closed-form k -of- n bound are prior work) and not a validated real-world defense. MITRE ATT&CK and the CIPHER harm corpus are real; the hospital is synthetic, since real hospital maps and per-incident telemetry are not public. Effectiveness and degradation are analyst-prior intervals anchored to published figures, never incident measurements, and the certificate verdicts are conditional worst-case frequencies under those intervals, not statistical confidence levels. The reference defenders are deliberately simple automated policies. The value of the range is that its score is a *provable* residual-risk bound rather than an average, and that an agentic defender can be dropped into the same API and held to the same guarantee—the natural next step.

Reproducibility. All numbers are generated from committed tables; the benchmark is deterministic (seeded random policy) and carries a provenance manifest over the pinned ATT&CK bundle and the CIPHER corpus. No LLM or network access is used.